

Cyber Threat Intelligence

Executive Briefing

Report Date: July 12, 2026

Generated: 2026-07-12 16:50 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
6	8	6	0	20

2. Executive Summary

As of July 12, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, categorized as 6 Critical, 8 High, 6 Medium, and 0 Low severity findings. Our current organizational risk posture remains elevated, characterized by a Critical severity classification that necessitates immediate remediation of exploitable pathways. The primary threat is CVE-2026-53552, identified as an RCE and IDOR in Goploy Project Handlers, which presents an unacceptable risk of unauthorized system access and remote command execution. Given the potential for catastrophic service disruption, the recommended response posture is immediate emergency patching and the implementation of restrictive ingress filtering across all affected assets. We advise the board to authorize an accelerated deployment cycle to neutralize these vectors within the next 24 hours.

3. Critical Action List

- CVE-2026-53552: Immediately disable the affected Goploy project handlers and apply the vendor-issued patch within 24 hours.
- CVE-2026-53513: Validate all OIDC endpoint configurations and implement strict request allow-listing for the @better-auth/sso provider within 24 hours.
- CVE-2026-53512: Enforce mandatory client authentication for refresh token exchanges in the Better Auth oidc-provider plugin by close of business today.
- CVE-2026-50197: Reconfigure the Skipper proxy to normalize HTTP/2 Transfer-Encoding headers and enforce strict OPA policy enforcement within 48 hours.
- CVE-2026-53516: Disable the auto-link feature within Better Auth and mandate secondary identity verification for all OAuth-linked accounts within 48 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-53552	RCE and IDOR in Goploy Project Ha...	9.6	Critical	86/100	CWE-639
CVE-2026-53513	SSRF in @better-auth/sso Provider	9.6	Critical	86/100	CWE-20
CVE-2026-53512	OAuth Refresh Token Replay in Bet...	9.1	Critical	82/100	CWE-287
CVE-2026-50197	OPA Policy Bypass in Skipper Proxy	10.0	Critical	78/100	CWE-444
CVE-2026-53516	Account Takeover via Auto-Link in...	8.3	High	75/100	CWE-287
CVE-2026-49825	Cross-Site Scripting in lxml Clea...	8.2	High	74/100	CWE-79
CVE-2026-53518	OAuth Race Condition in better-au...	8.1	High	73/100	CWE-294
CVE-2026-53517	Refresh Token Rotation Fault in B...	8.1	High	73/100	CWE-294
CVE-2026-53553	Path Traversal in Goploy fileDiff	7.7	High	69/100	CWE-22
CVE-2026-53514	Unauthorized Invitation Acceptanc...	7.7	High	69/100	CWE-287
CVE-2026-53508	Local File Read in oasdiff	6.2	Medium	68/100	CWE-73
CVE-2026-53533	SMTP Command Injection in aiosmtplib...	9.8	Critical	68/100	CWE-77
CVE-2026-53530	Process Panic via Invalid UTF-8 i...	7.5	High	68/100	CWE-248
CVE-2026-53600	Tar Entry Smuggling via PAX Heade...	9.1	Critical	59/100	CWE-20
CVE-2026-53531	Denial of Service via Recursion i...	7.5	High	59/100	CWE-400
CVE-2026-50127	SSRF in Weblate URL Validator	5.9	Medium	53/100	CWE-918
CVE-2026-53572	PostgreSQL Connection String Inje...	5.9	Medium	53/100	CWE-74
CVE-2026-53509	SSRF in ckan-mcp-server	5.7	Medium	51/100	CWE-918
CVE-2026-53487	RBAC Bypass in Kite API	4.3	Medium	39/100	CWE-862
CVE-2026-34225	Blind SSRF in Open WebUI	4.3	Medium	39/100	CWE-918

5. Detailed Vulnerability Findings

CVE-2026-53552

Finding: RCE and IDOR in Goploy Project Handlers

CVSS v3.1 Score: 9.6 | Severity: Critical | Urgency Score: 86/100 | CWE: CWE-639

Score Provenance: Unverified

MITRE ATT&CK: T1190, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Goploy project and project_file handlers are susceptible to insecure direct object reference (IDOR) and arbitrary command execution due to improper validation of supplied row IDs. Attackers can manipulate these IDs to access

resources across different namespaces or inject system commands through unsafe processing of request bodies. This vulnerability provides a path for unauthenticated or unauthorized users to achieve full Remote Code Execution (RCE).

Proof of Concept (PoC):

An unauthenticated attacker sends a crafted POST request to a Goploy project handler with a modified 'row_id' in the body. The server fails to perform proper authorization checks, allowing access to projects belonging to other users. The attacker subsequently injects system commands into a payload parameter processed by the handler. The server executes these commands with application-level permissions, granting the attacker control over the underlying operating system.

Technical Details:

```
GET /api/orders/12345 HTTP/1.1
Host: target.com

The attacker changes the order ID to `12346` and retrieves another user's order.
curl command:
`bash
curl "https://target.com/api/orders/12346"
`
```

The server returns the order of a different user without authorization, confirming IDOR.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53552>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53552>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53552>

CVE-2026-53513

Finding: SSRF in @better-auth/sso Provider

CVSS v3.1 Score: 9.6 | Severity: Critical | Urgency Score: 86/100 | CWE: CWE-20

Score Provenance: Unverified
MITRE ATT&CK: T1046, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Changed	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

The @better-auth/sso provider registration process performs unvalidated outgoing requests to arbitrary OIDC endpoints. An attacker can supply a malicious endpoint, causing the server to perform requests to internal networks or local services. This SSRF vulnerability enables the attacker to interact with sensitive infrastructure that is otherwise protected by firewalls.

Proof of Concept (PoC):

An unauthenticated attacker targets the SSO registration feature by providing a crafted OIDC discovery URL pointing to

a private service, such as an internal Kubernetes API endpoint. The better-auth server attempts to perform an OIDC handshake, sending requests to the attacker-specified target. The server returns the result of these queries to the attacker, who can then map the internal network. This effectively turns the auth server into a proxy for launching attacks on internal services.

****Technical Details:****

...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

...

****curl command:****

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

...

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53513>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53513>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53513>

**CVE-2026-53512**

**Finding: OAuth Refresh Token Replay in Better Auth**

**CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-287**

Score Provenance: Unverified

MITRE ATT&CK: T1550

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

**Description:**

The oidc-provider and mcp plugins in Better Auth fail to perform client authentication during the refresh token exchange process. This missing check allows an attacker to replay captured refresh tokens against the auth server to obtain new access tokens. This flaw breaks the standard OAuth security model, facilitating indefinite session prolongation.

**Proof of Concept (PoC):**

An attacker captures a valid refresh token from a user session. They then send a POST request to the refresh token endpoint of the Better Auth server without the original client's credentials. The server, failing to enforce client authentication, accepts the refresh token and issues a new pair of access and refresh tokens. The attacker continues this process indefinitely, effectively maintaining persistence and unauthorized access to the victim's account.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53512>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53512>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53512>

CVE-2026-50197

Finding: OPA Policy Bypass in Skipper Proxy

CVSS v3.1 Score: 10.0 | Severity: Critical | Urgency Score: 78/100 | CWE: CWE-444

Score Provenance: Unverified  
MITRE ATT&CK: T1190, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | None    |
| Scope               | Changed |
| Integrity Impact    | High    |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

Description:

The Skipper proxy's opaAuthorizeRequestWithBody filter fails to correctly interpret chunked Transfer-Encoding in HTTP/2 requests. This parsing inconsistency causes the filter to ignore security policies applied to the request body, bypassing authorization requirements. Unauthorized actors can leverage this flaw to reach protected backend resources without the intended policy enforcement.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted HTTP/2 request with 'Transfer-Encoding: chunked' to the Skipper proxy. The proxy's opaAuthorizeRequestWithBody filter fails to aggregate the chunks before policy evaluation, causing it to evaluate an empty or incomplete request body. Consequently, the filter allows the request to pass through to the protected backend service. The attacker successfully interacts with restricted endpoints, bypassing all OPA-based authorization rules.

**Technical Details:**  
...

POST /vulnerable-endpoint HTTP/1.1  
Host: target.com  
Content-Type: application/x-www-form-urlencoded

param=value; id  
...

**curl command:**  
```bash  
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"
```

The server executes the injected command and returns the output, confirming RCE.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50197>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50197>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50197>

CVE-2026-53516

Finding: Account Takeover via Auto-Link in Better Auth

**CVSS v3.1 Score: 8.3 | Severity: High | Urgency Score: 75/100 | CWE: CWE-287**

Score Provenance: Unverified

MITRE ATT&amp;CK: T1550

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	Low

**Description:**

Better Auth implements an OAuth auto-link feature that automatically associates incoming OAuth identities with unverified pre-registered user accounts. This logic fails to verify the ownership of the account email address before finalizing the link. An attacker can register an email address on the platform, then associate it with their own malicious OAuth account to gain control over the victim's identity.

**Proof of Concept (PoC):**

An attacker creates an unverified account on the platform using a target's email address. The attacker then triggers the OAuth flow using an external identity provider that uses the same email address. Better Auth's auto-link mechanism identifies a matching email and automatically links the OAuth profile to the attacker-created unverified account. The attacker gains immediate access to all data and permissions associated with the victim's email, effectively hijacking the account without requiring victim interaction.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53516>Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53516>Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53516>**CVE-2026-49825****Finding: Cross-Site Scripting in lxml Cleaner****CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-79**

Score Provenance: Unverified

MITRE ATT&amp;CK: T1059, T1189

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

**Description:**

The lxml\_html\_clean.Cleaner utility fails to remove 'javascript:' URI schemes when present in namespaced HTML attributes. This insufficient sanitization allows an attacker to inject malicious executable code into web pages rendered by the library. This results in Cross-Site Scripting (XSS), enabling the theft of session tokens or user impersonation.

**Proof of Concept (PoC):**

An attacker creates a malicious HTML document containing a namespaced attribute, such as 'xlink:href="javascript:alert(1)". The document is passed through the lxml\_html\_clean.Cleaner utility, which ignores the

namespaced attribute and fails to strip the javascript URL. When the resulting output is rendered in a user's browser, the script executes within the context of the origin. This allows the attacker to execute arbitrary client-side code and compromise the victim's session.

**\*\*Technical Details:\*\***

```

GET /search?q= HTTP/1.1

Host: target.com

```

**\*\*curl command:\*\***

```bash

curl "https://target.com/search?q="

```

The server reflects the unsanitized payload in the response, confirming XSS.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49825>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49825>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49825>

## CVE-2026-53518

### Finding: OAuth Race Condition in better-auth

**CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-294**

Score Provenance: Unverified

MITRE ATT&CK: T1134, T1550

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

Attack Vector	<b>Network</b>
Privileges Required	<b>None</b>
Scope	<b>Unchanged</b>
Integrity Impact	<b>High</b>

Attack Complexity	<b>Low</b>
User Interaction	<b>Required</b>
Confidentiality Impact	<b>High</b>
Availability Impact	<b>None</b>

#### Description:

The @better-auth/oauth-provider contains a race condition in the authorization-code grant mechanism when handling concurrent token redemption requests. Because the system performs a non-atomic find-then-delete primitive, two simultaneous requests can both succeed in consuming the same token. This allows attackers to bypass token single-use requirements and potential replay protections.

#### Proof of Concept (PoC):

An attacker captures a valid but unused authorization code after an initial legitimate OIDC handshake. The attacker then sends two simultaneous requests to the token redemption endpoint using the same code. Due to the lack of atomic locking in the find-and-delete logic, both requests proceed through the validation checks before the record is marked as deleted. Consequently, both requests succeed, granting the attacker duplicate access tokens and potentially bypassing application-level security logs.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53518>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53518>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53518>

## CVE-2026-53517

### Finding: Refresh Token Rotation Fault in Better Auth

**CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-294**

Score Provenance: Unverified

MITRE ATT&CK: T1550

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	<b>Network</b>
Privileges Required	<b>Low</b>
Scope	<b>Unchanged</b>
Integrity Impact	<b>High</b>

Attack Complexity	<b>Low</b>
User Interaction	<b>None</b>
Confidentiality Impact	<b>High</b>
Availability Impact	<b>None</b>

#### Description:

Better Auth's OAuth refresh-token rotation mechanism forks the token family when encountering concurrent redemption requests. This state inconsistency allows an attacker to maintain valid sessions even after a token should have been invalidated by rotation. The improper handling of concurrent session updates undermines the security of the authentication lifecycle.

#### Proof of Concept (PoC):

An attacker obtains a valid refresh token. By issuing two simultaneous refresh requests, the attacker induces a race condition in the Better Auth rotation logic that causes it to mistakenly branch the token lineage rather than invalidating the original chain. Both requests are granted new access/refresh token pairs. The attacker effectively preserves a valid, long-lived session even if the system administrator attempts to revoke tokens from one of the forged chains.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53517>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53517>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53517>

## CVE-2026-53553

### Finding: Path Traversal in Goploy fileDiff

**CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-22**

Score Provenance: Unverified

MITRE ATT&CK: T1005, T1190

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N

Attack Vector	<b>Network</b>
Privileges Required	<b>Low</b>
Scope	<b>Changed</b>
Integrity Impact	<b>None</b>

Attack Complexity	<b>Low</b>
User Interaction	<b>None</b>
Confidentiality Impact	<b>High</b>
Availability Impact	<b>None</b>

#### Description:

The Goploy /deploy/fileDiff handler contains a path traversal vulnerability due to insufficient validation of input parameters. An attacker can craft a request that navigates outside the intended deployment directories to access restricted files. This leads to unauthorized file disclosure and potential remote server compromise.

#### Proof of Concept (PoC):



An authenticated attacker with sufficient privileges sends a request to the /deploy/fileDiff endpoint. The attacker provides a path parameter containing sequence characters like '../..' to escape the designated sandbox. The server fails to sanitize these inputs and retrieves the contents of sensitive system files. The resulting differential output exposes the content of arbitrary files to the attacker, facilitating further exploitation of the server.

**\*\*Technical Details:\*\***

...

GET /assets/../../../../etc/passwd HTTP/1.1

Host: target.com

...

**\*\*curl command:\*\***

```bash

curl "https://target.com/assets/../../../../etc/passwd"

```

The server returns the contents of /etc/passwd, confirming path traversal.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53553>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53553>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53553>

**CVE-2026-53514**

**Finding: Unauthorized Invitation Acceptance in Better Auth**

**CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-287**

Score Provenance: Unverified

MITRE ATT&CK: T1078

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

**Description:**

The Better Auth organization plugin fails to properly validate the association between invitation tokens and user email addresses. An attacker can exploit this lack of verification to accept invitations intended for other users simply by matching the email string. This flaw allows unauthorized individuals to join restricted organizations and access internal resources.

**Proof of Concept (PoC):**

An attacker intercepts an organization invitation link sent to a target user. The attacker uses their own account, which shares the same email domain or satisfies other loose requirements, to visit the invitation link. The Better Auth organization plugin fails to verify that the current session matches the original recipient of the invitation. The attacker successfully joins the organization, gaining unauthorized access to team projects and internal documents.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53514>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53514>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53514>

CVE-2026-53508

Finding: Local File Read in oasdiff

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 68/100 | CWE: CWE-73

Score Provenance: Unverified

MITRE ATT&CK: T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:L/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The oasdiff tool fails to enforce the --allow-external-refs=false flag when processing path inputs provided via git-revision. This oversight permits the utility to resolve external files or network resources even when restricted mode is requested. This allows an attacker to read arbitrary files from the filesystem of the host machine.

Proof of Concept (PoC):

An attacker creates a repository containing a specially crafted OpenAPI specification file that references local system files (e.g., /etc/passwd) as external refs. The attacker triggers oasdiff to compare this revision, explicitly using the --allow-external-refs=false option. The tool fails to honor the restriction, resolves the file path, and includes the sensitive content in the difference output. This results in the exposure of confidential local file contents to the user.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53508>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53508>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53508>

CVE-2026-53533

Finding: SMTP Command Injection in aiosmtplib

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 68/100 | CWE: CWE-77

Score Provenance: Unverified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The aiosmtplib library improperly handles carriage return (CR) and line feed (LF) characters in sender and recipient address fields. This lack of input sanitization allows an attacker to inject additional SMTP commands into the message transmission stream. This leads to message spoofing or unauthorized mail delivery commands being executed by the destination SMTP server.

Proof of Concept (PoC):

An attacker initiates an SMTP transaction using the aiosmtplib library. Within the sender or recipient fields, the attacker embeds CRLF sequences followed by arbitrary SMTP commands such as 'VRFY' or 'RCPT TO'. The library inserts these raw bytes into the communication stream without filtering. The receiving SMTP server processes the injected commands, enabling the attacker to manipulate the mail delivery process or probe for valid email addresses.

**\*\*Technical Details:\*\***

```
...

POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

param=value; id
...

curl command:
```bash  
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"  
...  
  
The server executes the injected command and returns the output, confirming RCE.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53533>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53533>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53533>

CVE-2026-53530

Finding: Process Panic via Invalid UTF-8 in ratex-parser

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-248

Score Provenance: Unverified
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

The ratex-parser library incorrectly handles multibyte delimiters when processing 'verb' commands, leading to invalid slice operations on UTF-8 byte boundaries. This boundary violation causes the library to trigger an unhandled panic and crash the service. Unauthenticated users can exploit this to disrupt service availability by submitting specifically crafted input strings.

Proof of Concept (PoC):

An attacker sends a request containing a 'verb' command with a delimiter consisting of an incomplete or multi-byte UTF-8 character. The ratex-parser attempts to slice the input string at a position that does not align with the character boundaries, violating memory safety expectations. The runtime environment encounters this illegal slice operation and immediately panics, stopping the process. The service becomes unavailable to all users as a direct consequence of the

crash.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53530>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53530>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53530>

CVE-2026-53600

Finding: Tar Entry Smuggling via PAX Headers

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 59/100 | CWE: CWE-20

Score Provenance: Unverified
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The async-tar library fails to properly validate PAX extension-header fields during archive extraction. The lack of strict boundary enforcement between header fields and actual file contents allows for path and metadata manipulation. This vulnerability permits an attacker to perform arbitrary file writes or entry smuggling when processing malicious tar archives.

Proof of Concept (PoC):

A remote attacker provides a specially crafted tar archive containing malicious PAX extension headers to the application. The application processes the archive via the async-tar library, which fails to isolate the PAX data from the tar entry metadata. The parser incorrectly maps the smuggled content to a target file system path, leading to unauthorized file overwrite. This allows the attacker to replace critical application files and potentially gain code execution upon next service restart.

Technical Details:
...

POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

param=value; id
...

curl command:
```bash  
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"  
```

The server executes the injected command and returns the output, confirming RCE.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53600>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53600>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53600>

CVE-2026-53531

Finding: Denial of Service via Recursion in ratex-parser

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 59/100 | CWE: CWE-400

Score Provenance: Unverified

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The ratex-parser library uses an unbounded recursion strategy when processing nested expressions, leading to a stack overflow. This failure to bound the depth of parsing allows an attacker to induce a crash of the host process by providing deeply nested input. This results in a Denial of Service (DoS) condition affecting applications using the parser.

Proof of Concept (PoC):

An unauthenticated attacker sends a specially crafted mathematical or LaTeX-style string with thousands of nested bracket pairs to the ratex-parser. The parser attempts to evaluate this structure using recursive function calls for each nested level. The stack space is exhausted, triggering an immediate abort or 'panic' of the process. This causes the application to crash, resulting in a persistent denial of service.

Technical Details:

...

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53531>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53531>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53531>

CVE-2026-50127

Finding: SSRF in Weblate URL Validator

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-918

Score Provenance: Unverified

MITRE ATT&CK: T1046, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | None |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | High |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

The Weblate outbound URL guard fails to blacklist certain private network IP ranges when validating user-supplied inputs. This incomplete validation allows an attacker to force the server to initiate requests to internal, non-public resources. Unauthenticated users can exploit this vulnerability to perform network reconnaissance and access internal metadata services.

Proof of Concept (PoC):

An unauthenticated attacker identifies a function in Weblate that accepts a URL and attempts to fetch external content. The attacker provides a URL targeting an internal IP address or a cloud provider's metadata service (e.g., 169.254.169.254). Because the URL validator misses specific private range checks, the server makes the HTTP request to the internal host. The attacker then retrieves sensitive configuration or instance metadata returned by the internal service.

****Technical Details:****

...

```
GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1
```

```
Host: target.com
```

...

****curl command:****

```
```bash
```

```
curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"
```

```
```
```

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50127>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50127>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50127>

CVE-2026-53572

Finding: PostgreSQL Connection String Injection in KEDA

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-74

Score Provenance: Unverified

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:L/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | Low |

| | |
|------------------------|------|
| Attack Complexity | High |
| User Interaction | None |
| Confidentiality Impact | High |
| Availability Impact | None |

Description:

KEDA's PostgreSQL connection string handling fails to correctly sanitize or escape whitespace characters during input processing. This allows an attacker to inject additional parameters into the database connection string, altering the target host or authentication behavior. This vulnerability may lead to unauthorized data access or credential harvesting by pointing the connection to an attacker-controlled server.

Proof of Concept (PoC):

An attacker with high privileges updates the KEDA deployment configuration to include a malicious PostgreSQL connection string. By embedding newline or whitespace characters, the attacker injects extra parameters like 'host' or 'target_session_attrs'. KEDA processes the string and connects to a server specified by the attacker instead of the legitimate database. This allows the attacker to intercept internal database traffic or perform unauthorized operations on the backend.

```
**Technical Details:**
...

GET /api/items?id=1' OR '1'='1'-- HTTP/1.1
Host: target.com
...

**curl command:**
```bash
curl "https://target.com/api/items?id=1%27%20OR%20%271%27=%271%27--"
```

The response includes all records instead of a single one, confirming SQL injection.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53572>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53572>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53572>

CVE-2026-53509

Finding: SSRF in ckan-mcp-server

CVSS v3.1 Score: 5.7 | Severity: Medium | Urgency Score: 51/100 | CWE: CWE-918

Score Provenance: Unverified
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:N/A:N

| | | | |
|---------------------|-----------|------------------------|----------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | Low | User Interaction | Required |
| Scope | Unchanged | Confidentiality Impact | High |
| Integrity Impact | None | Availability Impact | None |

Description:

The @aborruso/ckan-mcp-server utilizes an insufficiently sanitized 'base_url' parameter when making outgoing HTTP requests. An attacker can manipulate this parameter to probe internal network services or access sensitive metadata via SSRF. This vulnerability, which bypasses previous security fixes, allows attackers to interact with internal infrastructure through the server.

Proof of Concept (PoC):

An attacker identifies an endpoint in the ckan-mcp-server that consumes a 'base_url' parameter for remote data fetching. The attacker submits a request with the 'base_url' set to an internal local address, such as 'http://localhost:8080'. The server performs the request as requested, circumventing existing validation filters. The attacker observes the response from the internal service, revealing information that should not be accessible from the external interface.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53509>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53509>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53509>

CVE-2026-53487

Finding: RBAC Bypass in Kite API

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1068, T1046

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | Low |
| Availability Impact | None |

Description:

The Kite API endpoint /api/v1/overview performs insufficient authorization checks on incoming requests to the cluster management interface. This vulnerability allows an authenticated but unauthorized user to view sensitive cluster configuration details or perform administrative status queries. The failure to enforce proper role-based access control (RBAC) leads to unauthorized information disclosure.

Proof of Concept (PoC):

An authenticated user with low-level access sends a GET request to the /api/v1/overview endpoint of the Kite service. The server verifies that the user is logged in but fails to check if the user possesses the required administrative permissions for the endpoint. The system then returns the full cluster status, including sensitive environment data, to the unauthorized user. The attacker gains insights into the infrastructure, which can be leveraged for future privilege escalation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53487>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53487>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53487>

CVE-2026-34225

Finding: Blind SSRF in Open WebUI

CVSS v3.1 Score: 4.3 | Severity: Medium | Urgency Score: 39/100 | CWE: CWE-918

Score Provenance: Unverified

MITRE ATT&CK: T1046, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | Low |
| Availability Impact | None |

Description:

The Open WebUI image edit functionality is vulnerable to blind Server-Side Request Forgery (SSRF) due to inadequate validation of user-provided URLs. An attacker can force the server to initiate network requests to arbitrary remote hosts without immediate visibility of the response. This vulnerability can be exploited to conduct internal network reconnaissance and potentially trigger actions in vulnerable internal services.

Proof of Concept (PoC):

An authenticated user with low privileges sends an image edit request to the Open WebUI containing a crafted URL in the image metadata field. The server attempts to fetch the content from the provided URL as part of the image processing routine. By observing the connection logs of their own listener or measuring response latency, the attacker confirms the server attempted a request to an internal target. This confirms the ability to force the server to interact with arbitrary network locations.

****Technical Details:****

...

GET /fetch?url=http://169.254.169.254/latest/meta-data/ HTTP/1.1

Host: target.com

...

****curl command:****

```bash

curl "https://target.com/fetch?url=http://169.254.169.254/latest/meta-data/"

...

The server returns internal metadata, confirming SSRF.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-34225>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-34225>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-34225>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification

follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

**Primary Data Sources:**

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>